

THE FORENSICS WAY

ISSUE 28

FORENSICS AWARENESS THIS WEEK

TUESDAY, AUGUST 11, 2026

FRONT PAGE

SUPPLY CHAIN

A Trusted Maintainer, a Preinstall Hook, 1.3 Billion Downloads a Month: CHAINDROP Turns Your Own "npm install" Against You

Elastic Security Labs and a coalition of vendors — Microsoft, Palo Alto, Snyk, Wiz, Socket — documented CHAINDROP, the latest strain of the self-propagating Shai-Hulud worm, after attackers compromised the maintainer of the widely used *keyv* library. The worm inserted a malicious preinstall hook into package.json across more than 400 packages and 2,200 published versions, meaning the infostealer fires the moment a developer runs a routine install or update — no import, no execution of application code required. It harvests npm and GitHub tokens, AWS credentials, Kubernetes secrets, HashiCorp Vault tokens, and Stripe and Slack keys, then uses captured npm tokens to republish trojanized versions of every package the victim can touch.

Command-and-control resolves through an Ethereum smart contract, giving the worm a takedown-resistant address book as it spreads. This is automated supply-chain compromise at a scale that outruns manual triage: a single maintainer account breach cascaded into 1.3 billion monthly downloads of tainted code before defenders could react. Forensic priority: audit CI/CD pipelines and build logs for anomalous npm publish events, rotate every credential type the malware targets — not just npm tokens — and treat any package with a recently modified preinstall script as suspect pending review.

AI THREATS

The Documentation Was the Weapon: Attackers Hide Payment Instructions in Fake API Pages to Trick AI Agents Into Wiring Crypto

Zscaler researchers detailed a wave of indirect prompt injection campaigns weaponizing search results and documentation pages against autonomous AI coding agents. Attackers use SEO poisoning to rank fake API documentation for popular developer

Threat Bulletin

ACTIVE EXPLOIT

CVE-2026-9198

Langflow OSS — an insecure default lets any network caller mint a SUPERUSER token from /api/v1/auto_login, which is then used to POST Python straight into /api/v1/validate/code for in-process execution via exec(); CVSS 9.8, unauthenticated, no user interaction. Fixed in 1.10.1; added to CISA KEV August 4 after confirmed exploitation. *Forensic Note:* Review Langflow logs for auto_login calls from unexpected hosts followed by validate/code POSTs, and hunt for dropped payloads on hosts running pre-1.10.1 instances.

ACTIVE EXPLOIT

CVE-2026-18556 / CVE-2026-18577

N-able N-central — an authentication bypass (CVSS 8.2) let attackers gain administrative RMM access and use the platform's Take Control feature to reach managed endpoints; N-able's first patch proved incomplete, and a second bypass (18577) was exploited before the follow-up fix landed. Both added to CISA KEV in early August after confirmed customer compromises. *Forensic Note:* Audit N-central admin logins and Take Control session logs for anomalous activity, and treat every managed endpoint as potentially touched until confirmed otherwise.

MALWARE SPOTLIGHT

Nova Ransomware — The Rust Encryptor That Blinds Defender First

queries, then hide instructions in the page's DOM using off-screen CSS positioning and JSON-LD metadata — invisible to a human visitor but fully readable by an agent scraping the page for instructions. The payload persuades the agent that a small payment is a required setup step, then routes funds via a Stripe checkout link or a hardcoded Ethereum wallet. Tests showed the technique fooling multiple current-generation models.

Where CHAINDROP automates the exploitation of trust in a package registry, this campaign automates the exploitation of trust in a search result — both aim at the machine doing the reading, not the human. Forensic priority: log and review every URL an AI agent fetches during autonomous tasks, treat unexpected payment prompts or wallet addresses surfaced mid-task as a compromise indicator, and audit agent tool-call transcripts for instructions that originated from fetched content rather than the user.

Analyzed by AttackIQ, Nova is a 64-bit Rust encryptor that opens with a multi-layered defense-evasion routine — reconfiguring Microsoft Defender, killing security services, and terminating any process that looks like a debugger or monitoring tool — before deleting Volume Shadow Copies via vssadmin and WMI. It encrypts with XChaCha20-Poly1305 and RSA-2048, appends the .xgWLckNV extension, drops a README_NOVA.me note, and self-deletes on completion. *Forensic Note:* Hunt Defender configuration-change events and mass service termination as an early-warning pair, capture volatile memory before self-deletion completes, and recover shadow-copy deletion commands from event logs.

— PAGE 1 —

THE FORENSICS WAY

HISTORICAL ARCHIVES

HISTORY OF DIGITAL INVESTIGATION

TUESDAY, AUGUST 11, 2026

CASE STUDIES: HISTORICAL GRID

THE EVENT-STREAM INCIDENT (2018)

A Handshake, Not a Hack: How Asking Nicely for Publish Rights Poisoned a Package Downloaded Millions of Times a Week

In November 2018, a developer using the alias "right9ctrl" simply asked the maintainer of the popular npm package event-stream to take over maintenance — no exploit required — then quietly added a dependency, flatmap-stream, carrying an encrypted payload aimed narrowly at the Copay Bitcoin wallet app. A routine code review by another developer, Jayden Seric,

GOOTLOADER (2020–PRESENT)

Poisoning the Search Result Instead of the Inbox: The Malware That Weaponized Google Before It Weaponized a Document

Since 2020, the Gootloader operation has ranked fake legal-document and business-template pages at the top of search results through aggressive SEO poisoning, luring professionals searching for contracts into downloading a JavaScript-based loader disguised as the file they wanted. Investigators traced the campaign's staying power to its manipulation of the search

caught the anomaly before it detonated at wider scale, and the incident became a landmark case for social-engineered maintainer takeovers. It is the direct ancestor of this week's CHAINDROP: the exact same trust relationship — a compromised maintainer account — now automated into a self-propagating worm across 400-plus packages instead of one.

layer itself rather than any single payload, forcing defenders to treat "what a search engine surfaces" as an attack surface in its own right. That exact technique — poisoning what an automated reader trusts — is what this week's fake-API-documentation campaign aims at AI agents instead of humans, one generation of the same con later.

THE MORRIS WORM (1988)

The First Autonomous Intruder: A Graduate Student's Experiment That Breached 6,000 Machines With No One at the Keyboard

In November 1988, a self-replicating program written by Cornell student Robert Tappan Morris escaped its author's control and infected an estimated 6,000 machines — roughly a tenth of the young internet — by autonomously exploiting sendmail, fingerd, and weak passwords. With no packet captures and no EDR, investigators at Berkeley, MIT, and Purdue decompiled the worm's code itself, making Gene Spafford's analysis one of the founding documents of malware forensics, and the case produced the first conviction under the Computer Fraud and Abuse Act. Nearly four decades before CHAINDROP republished itself across 400 packages, Morris proved the defining problem: once code can propagate on its own, the investigation starts with reverse-engineering its intent.

ZEUS (2007)

Stealing the Session, Not the Password: The Banking Trojan That Invented the Hidden Browser and Built a Criminal Industry

Surfacing in 2007, the Zeus trojan redefined financial malware by hijacking what victims already had: authenticated online-banking sessions, manipulated in real time through web injects and hidden-VNC modules that let operators drive the victim's browser invisibly, from the victim's own IP. The FBI's 2010 Operation Trident Breach charged over 100 money mules moving roughly \$70 million, and after the source code leaked in 2011, Zeus's architecture spawned Gameover Zeus and a decade of descendants. Forensically, Zeus forced investigators to stop treating a "clean" login as innocent and start reconstructing session behavior — the same discipline Nova's defense-evasion routine and this week's identity-driven attacks still demand.

TOOLS OF THE TRADE

OPEN SOURCE

Hayabusa

YAMATO SECURITY — V4.0.0

Freshly unveiled at Black Hat Arsenal USA, the Windows event-log analyzer's v4.0.0 release speeds up Sigma-rule sweeps across EVTX at scale. Point it at hosts touched by Nova's defense-evasion routine

OPEN SOURCE

suzaku

YAMATO SECURITY — V2.0.0

Hayabusa's cloud-log sibling also debuted at Black Hat Arsenal, built to hunt AWS, Azure, and M365 logs the same way its Windows counterpart hunts EVTX. A natural fit for tracing the credential trail after a CHAINDROP-

UTILITY / SCRIPT

Malwoverview

ALEXANDRE BORGES — V8.1.0

The malware triage framework's latest release streamlines fast static and sandbox-backed lookups against threat-intel feeds. Feed it Nova samples or CHAINDROP's preinstall payloads to get rapid classification before

COMMERCIAL

PC-3000 Mobile PRO

ACELAB — V2.12X

The mobile hardware-forensics platform's latest build extends chip-off and JTAG acquisition support for current device generations. Essential when an investigation moves from the network layer down to a physically

to surface Defender configuration changes and mass service kills in one timeline pass.	style CI/CD compromise across cloud environments.	committing to a full reverse-engineering pass.	damaged or locked handset that software extraction alone can't reach.
--	---	--	---

PRIORITY CVE ADVISORIES

ARCHIVE ALERT

CVE-2026-16812 (ARISTA VELOCLOUD ORCHESTRATOR)

Unauthenticated OS command injection in the on-prem VCO web interface; CVSS 10.0 with scope change to every managed SD-WAN edge. Exploited as a zero-day; CISA KEV. *Forensic Note:* Review VCO web logs for anomalous requests and hunt injected commands and dropped payloads on the host.

ARCHIVE ALERT

CVE-2026-20316 (CISCO SECURE FMC)

A hard-coded password lets an unauthenticated attacker log in as a built-in low-privilege account and read firewall rules, VPN configs, and event logs; CVSS 8.9. Exploited in the wild; CISA KEV, federal deadline August 1. *Forensic Note:* Audit FMC authentication history for the built-in account and review policy exports for reconnaissance.

RECENT MALWARE WATCH

ARCHIVE: AUGUST 4, 2026

MEDUSAHVNC — THE BROWSER ON THE DESKTOP YOU CANNOT SEE

Sold as MaaS via website and Telegram, MedusaHVNC spawns a hidden Windows desktop and opens a browser with the victim's real profile, so fraud flows from the victim's own IP. A five-stage chain ends with Autolt injection into charmap.exe over ChaCha20-encrypted custom TCP. Hunt charmap.exe with network connections and enumerate hidden desktops in memory captures.

ARCHIVE: JULY 28, 2026

STARLAND RAT — THE TROJAN BEHIND THE FAKE INSTALLER

Tracked by Cisco Talos to UAT-11795, Starland rides trojanized Zoom, WebEx, MobaXterm, and DBeaver installers to inventory AD data and scan 40-plus crypto wallets, with a Polygon smart contract as fallback C2. Hunt mshta.exe spawning NSIS installers and outbound Polygon RPC calls.